Ota haavoittuvuudet haltuun: Moderni pilvitietoturva ulkoa ja sisältä

Markus Lintuala
Jussi Roine



Arrow x Microsoft Kumppaniarkkitehtiseminaari 12.6.2025
aka.ms/kumppaniarkkitehtiseminaari



Markus

SIERRA



Jussi



Not Bad
Security

The Business Problem

In practice

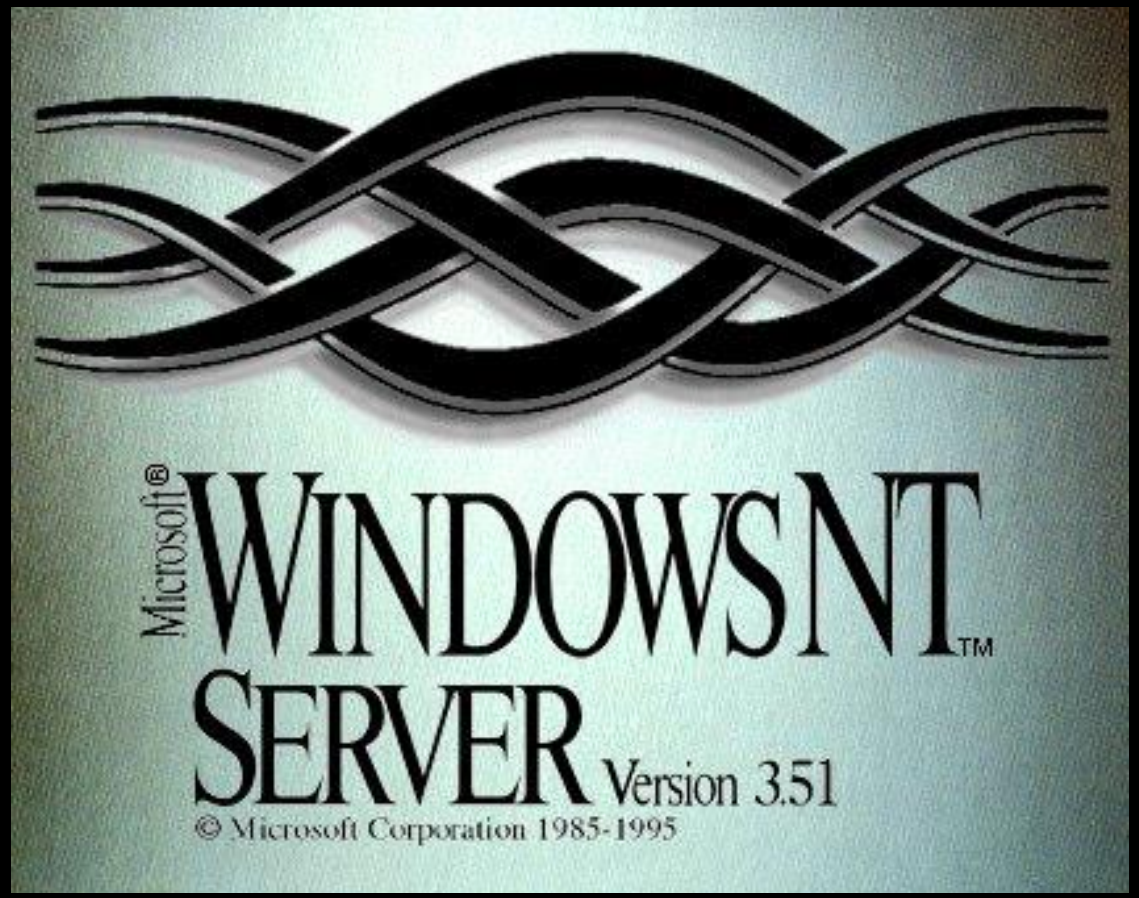


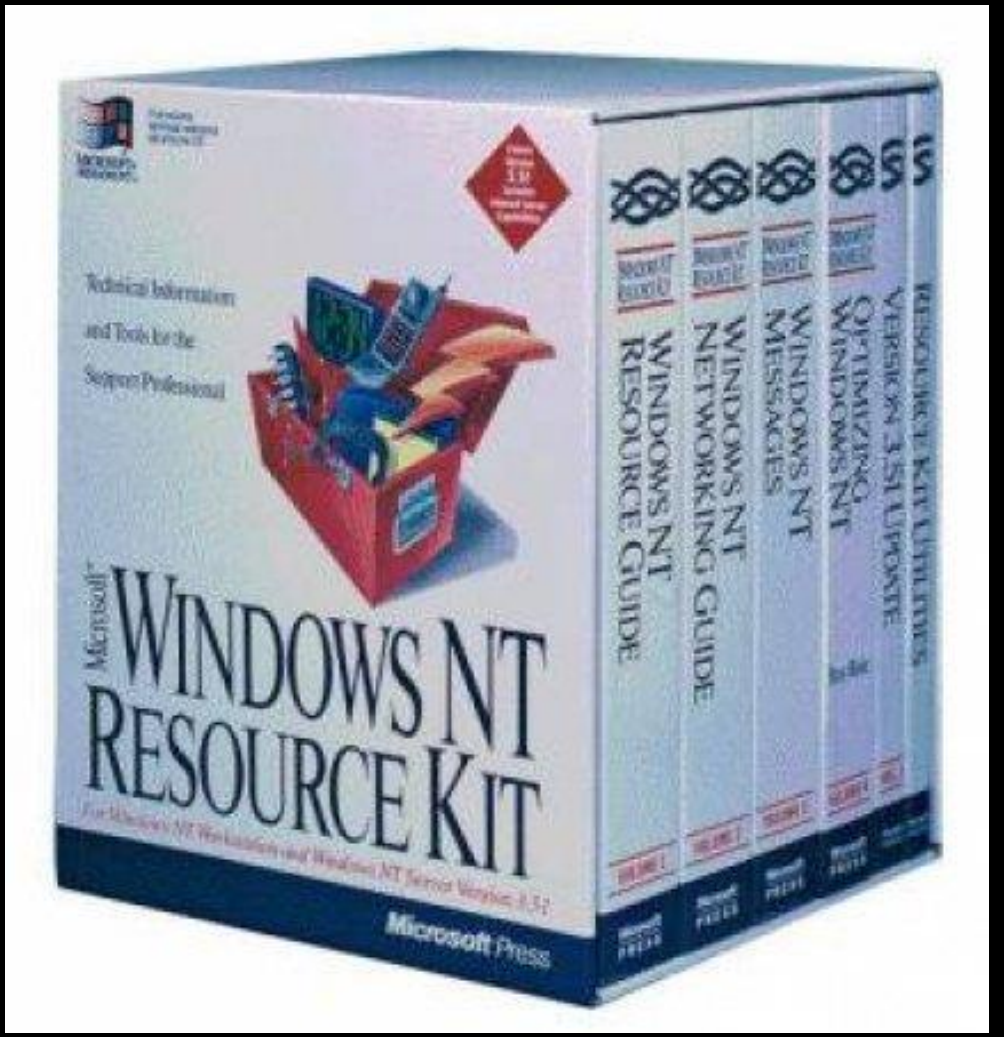
MSEM & Defender EASM

Lessons learned

The business problem

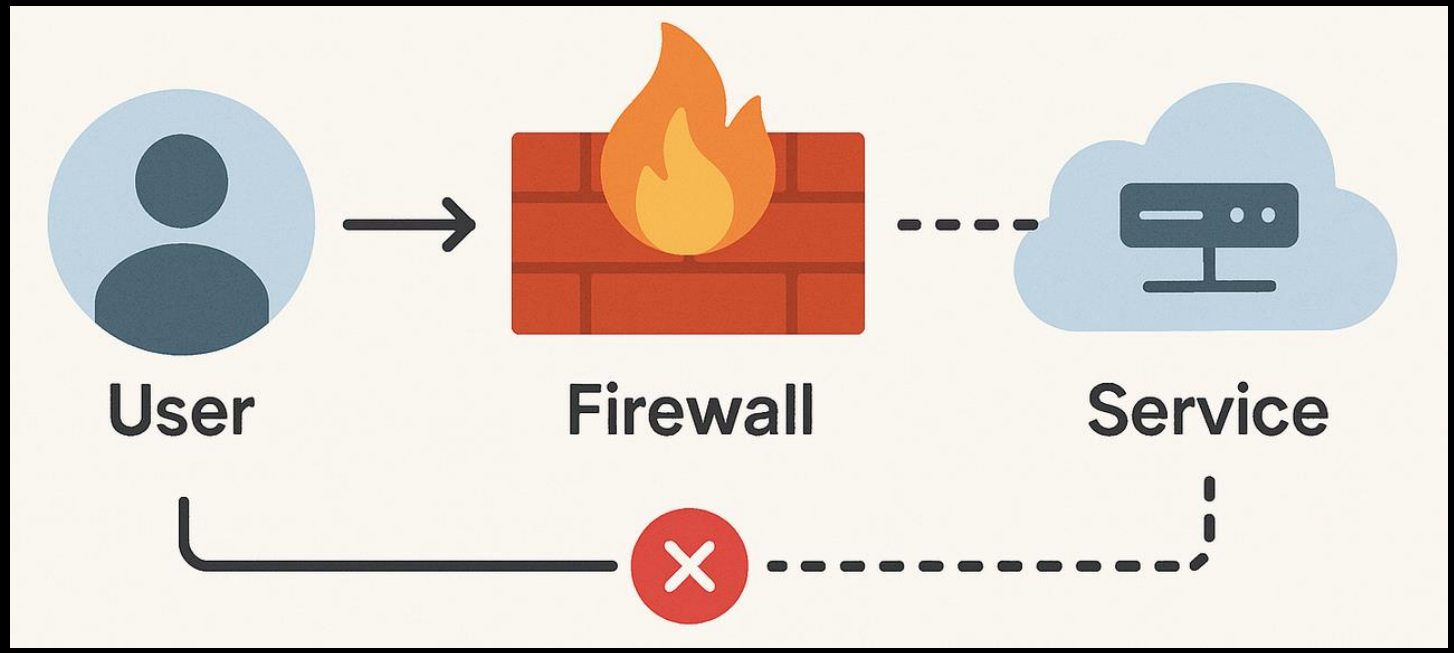



Microsoft®
WINDOWS NT™
SERVER Version 3.51
© Microsoft Corporation 1985-1995


Technical Information and Tools for the Support Professional
Microsoft
WINDOWS NT
RESOURCE KIT
Microsoft Press
WINDOWS NT RESOURCE GUIDE
WINDOWS NT NETWORKING GUIDE
WINDOWS NT MESSAGES
OPTIMIZING WINDOWS NT
VERSION 3.51 UPDATE
RESOURCE KIT UTILITIES

1996: Skills, work and challenges back then

Security focusing on identities, firewalls and passwords

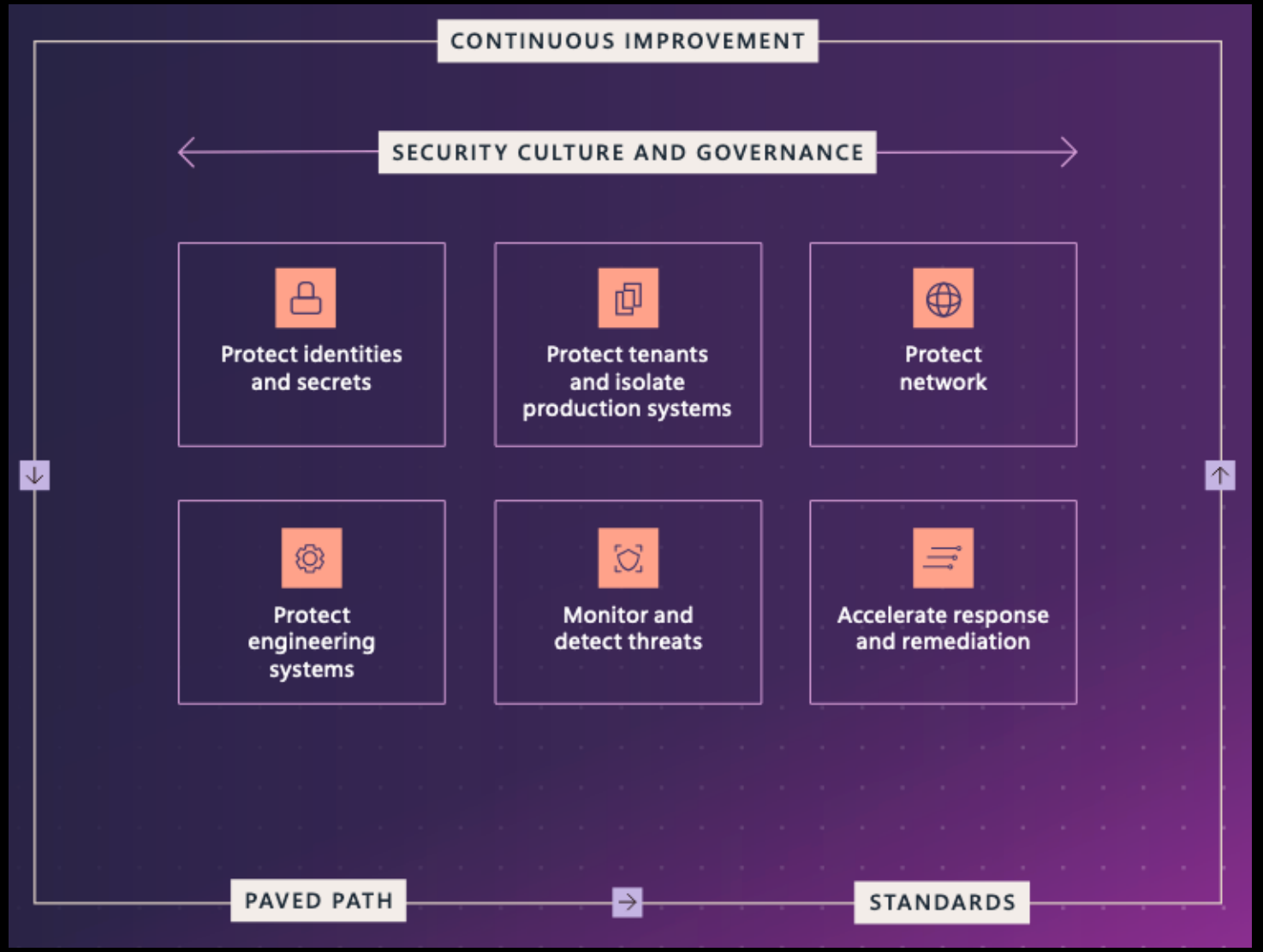


The State of Security: Microsoft Digital Defense Report 2024

600 million identity attacks per day – 7,000 password attacks per second.

In more than 90% of cases where attacks progressed to ransom stage, the attacker had leveraged unmanaged devices in the network.

Password-only authentication configurations, exacerbated by archaic expiry and complexity policies, result in more than 99% of identity compromises.



https://www.microsoft.com/en-us/security/security-insider/intelligence-reports/microsoft-digital-defense-report-2024

Insights from Microsoft

ROM	Issues found	% of customers with the issue
Higher		
15	No advanced MFA protection mechanisms enabled	37%
15	Poor user lifecycle management	21%
15	Lack of EDR coverage	13%
15	Lack of detection controls	10%
13	Resource exposed to public access	2%
12	Insufficient protections for local accounts	60%
12	Missing security barrier between cloud and on-premise	54%
11	Insecure Active Directory configuration	43%
11	No advanced password protection enabled	37%
11	Missing content based MFA protection mechanisms	24%
11	Insecure operating system configuration	3%
Medium		
	Legacy and unsecure protocols	18%
6	Missing cloud application management and monitoring	21%
6	No privileged identity management solution	8%
6	No MFA, or MFA not mandatory for privileged accounts	21%
6	Weak email protection against common threats	16%
6	Legacy or unsupported operating systems	14%
Lower		
4	No privilege separation	41%
4	No hardened workstations used for administration	23%
4	Missing data classification and sharing restrictions	5%
3	No vulnerability management	30%
2	No adherence to the Least Privilege Principle	63%

https://www.microsoft.com/en-us/security/security-insider/microsoft-digital-defense-report-2023

Microsoft security capability mapping

Which roles typically use which capabilities

April 2025 – https://aka.ms/MCRA

Access Control

Establish **Zero Trust** access model to modern and legacy assets using identity & network controls

Microsoft Entra

Identity Admin, Identity Architect, Identity Security

- **Entra ID (Formerly Azure AD)**
  - Multifactor Authentication
  - Conditional Access
  - Application Proxy
  - External Identities / B2B & B2C
  - Internet/Private Access
  - Identity Governance
  - and more..
- **Windows Hello for Business**
- **Microsoft 365 Defender**
  - Microsoft Defender for Identity
  - Microsoft Defender for Cloud Apps
- **Microsoft 365 Lighthouse** *[multi-tenant]*
- **Azure Lighthouse** *[multi-tenant]*
- **Azure Bastion**
- *Azure Administrative Model*
  - *Portal, Management Groups, Subscriptions*
  - *Azure RBAC & ABAC*

Network Security

- **Azure Firewall**
- **Azure Firewall Manager**
- **Azure DDoS**
- **Azure Web Application Firewall**
- *Azure Networking Design*
  - *Virtual Network, NSG, ASG, VPN, etc.*
  - *PrivateLink / Private EndPoint*

Endpoint / Device Admin

- **Microsoft Intune**
  - Configuration Management
- **Microsoft Defender for Endpoint**

Security Operations

Detect, **Respond**, and **Recover** from attacks; Hunt for hidden threats; share threat intelligence broadly

Incident preparation

Microsoft Defender

Security Operations Analyst

Microsoft Defender XDR

- Microsoft Defender for Endpoint
- Microsoft Defender for Office 365
- Microsoft Defender for Identity
- Microsoft Defender for Cloud Apps
- Microsoft Entra Identity Protection
- *Microsoft Defender for Cloud*
  - Microsoft Defender for DevOps
  - Microsoft Defender for Servers
  - Microsoft Defender for Storage
  - Microsoft Defender for SQL
  - Microsoft Defender for Containers
  - Microsoft Defender for App Service
  - Microsoft Defender for APIs
  - Microsoft Defender for Key Vault
  - Microsoft Defender for DNS
  - Microsoft Defender for open-source relational databases
  - Microsoft Defender for Azure Cosmos DB
- **Microsoft Security Copilot**
- **Microsoft Sentinel**
- **Microsoft Security Experts**
- *Microsoft Incident Response*
  Detection and Response Team (DART)

Threat intelligence Analyst

- **Microsoft Defender Threat Intelligence (Defender TI)**
- **Microsoft Sentinel**

Security Governance

Protect sensitive data and systems. Continuously discover, classify & secure assets

Security architecture

- *Microsoft Cybersecurity Reference Architecture* https://aka.ms/MCRA

Posture management, *Policy and standards*, *Compliance management*

- **Microsoft Defender for Cloud**
  - *Secure Score*
  - *Compliance Dashboard*
  - *Azure Security Benchmark*
- **Azure Blueprints**
- **Azure Policy**
- **Microsoft Defender External Attack Surface Management (MD-EASM)**
- **Microsoft Security Exposure Management (MSEM)**
- *Azure Administrative Model*
  - *Portal, Management Groups, Subscriptions*
  - *Azure RBAC & ABAC*
- **Microsoft Purview**
  - Compliance manager

Microsoft Purview

Data security

- **Microsoft Purview**
  - Information Protection
  - Data Loss Prevention
- **Microsoft 365 Defender**
  - Microsoft Defender for Cloud Apps

People security

- **Attack Simulator**
- **Insider Risk Management**

Privacy Manager

- **Microsoft Priva**

Asset Protection

Continuously **Identify**, measure, and manage security posture to reduce risk & maintain compliance

Infrastructure and endpoint security, *IT Ops*, *DevOps*

- **Microsoft Defender for Cloud** *(including Azure Arc)*
- **Azure Blueprints**
- **Azure Policy**
- **Azure Firewall**
- **Azure Monitor**
- **Azure Web Application Firewall**
- **Azure DDoS**
- **Azure Backup and Site Recovery**
- *Azure Networking Design*
  - *Virtual Network, NSG, ASG, VPN, etc.*
  - *PrivateLink / Private EndPoint*
- *Azure Resource Locks*

OT and IoT Security

- **Microsoft Defender for IoT** *(& OT)*
- **Azure Sphere**

Innovation Security

Integrate Security into **DevSecOps** processes. Align security, development, and operations practices.

Application security and DevSecOps

- *(Same as Infrastructure Roles)*
- **GitHub Advanced Security**
- *Azure DevOps Security*

It’s not about a specific product.

It’s about people and processes.

risk x exception x compliance


Microsoft Security Exposure Management
&
Defender External Attack Surface Management

Effective Exposure Management

Identify and classify critical assets

Discover intrusion paths

Communicate risk to business leaders

Secure Score vs. Security Exposure Management

MSEM

Unified view of security posture, attack surface and security risk exposure.

Includes Secure Score + MDC.

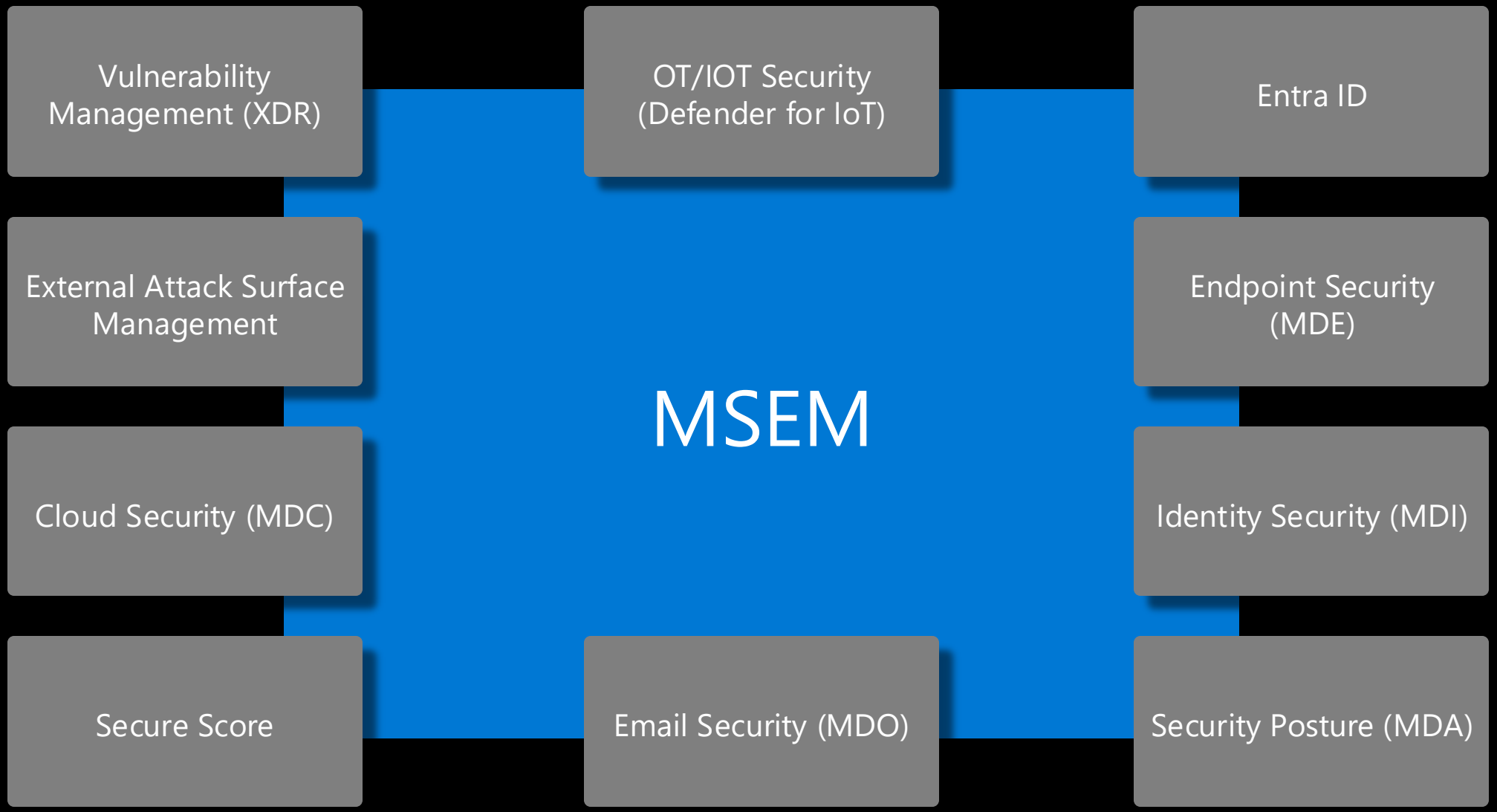
Recommendations insights.

Secure Score

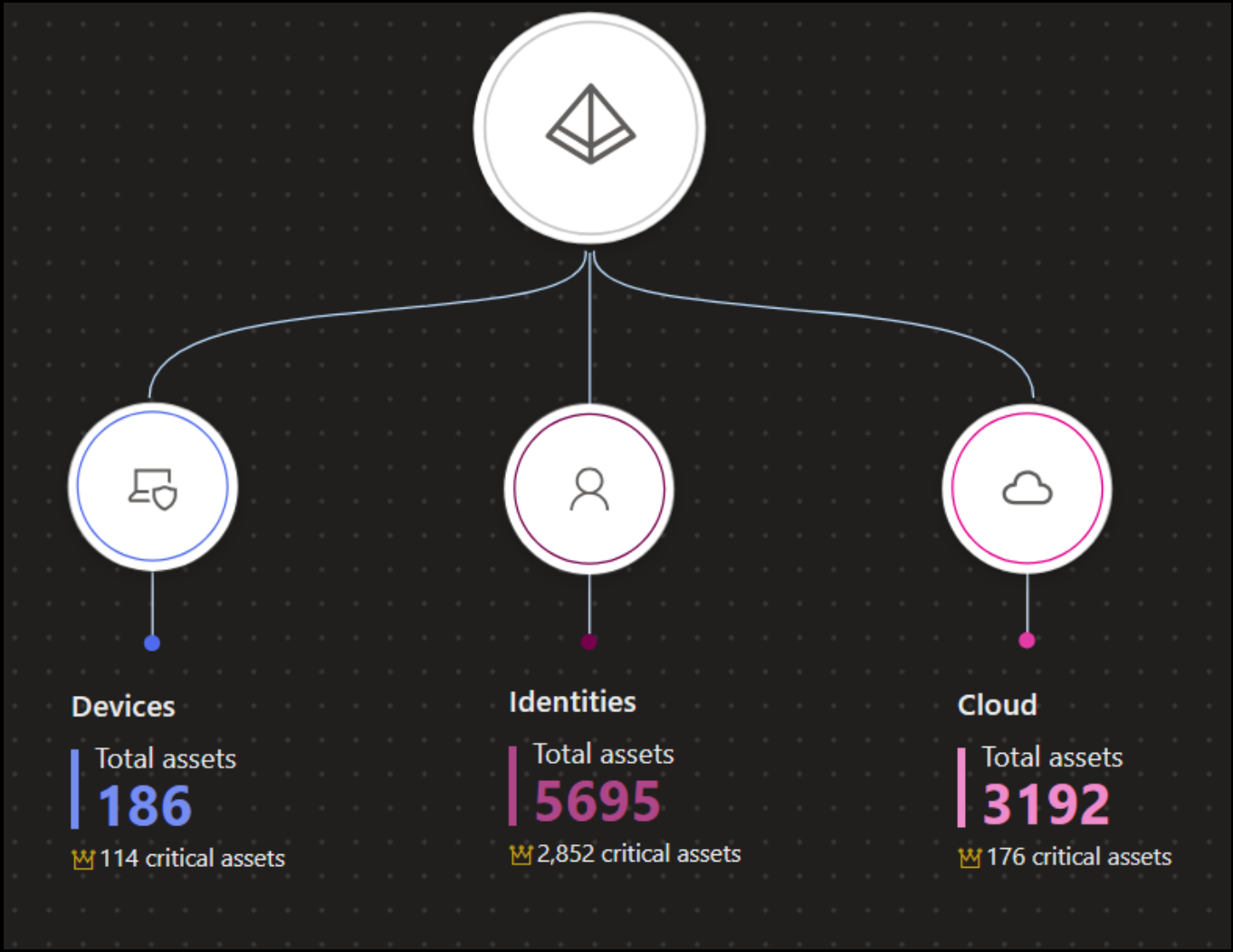
Baseline and benchmark for security posture – focus on Defender products.

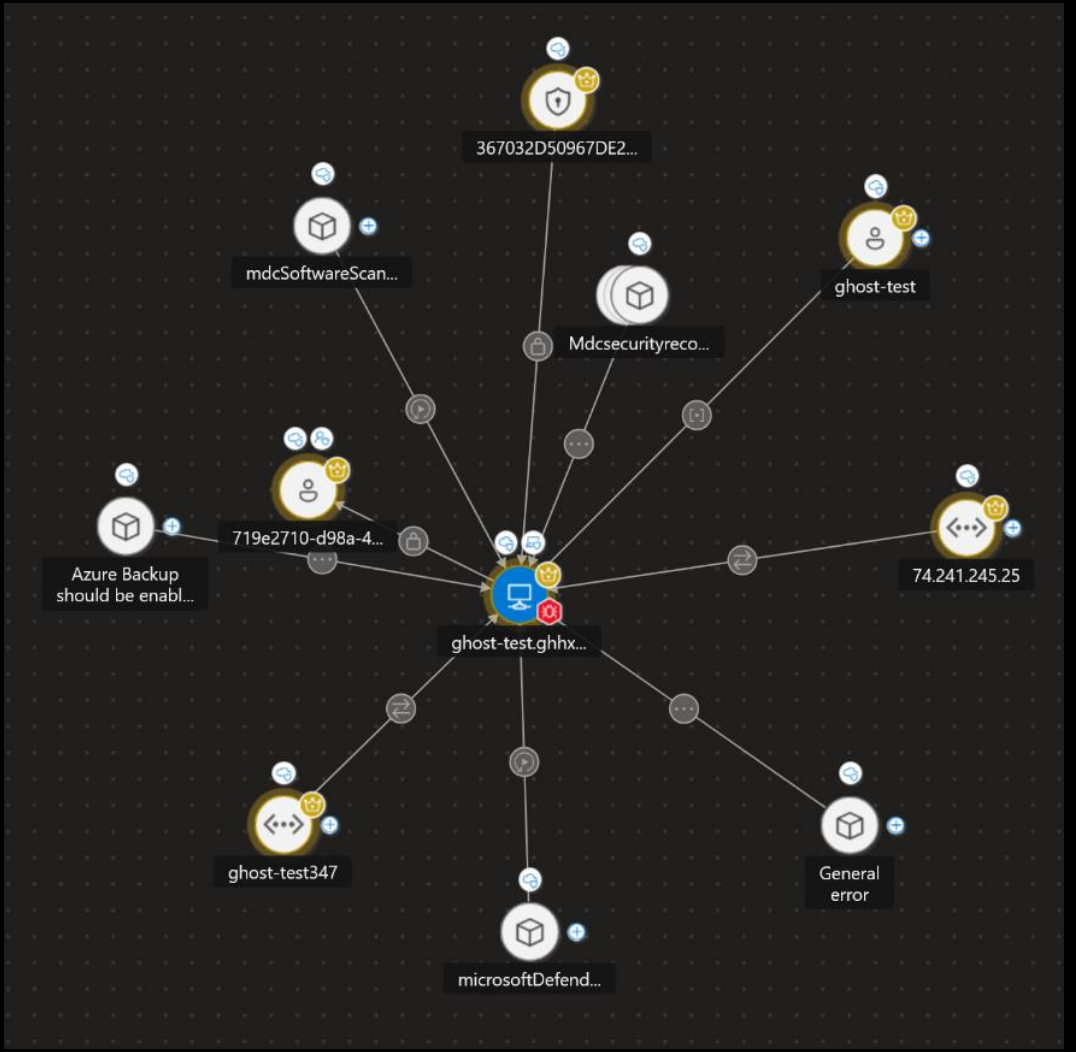
Controls and metrics.

MSEM signals and data



Attack Surface

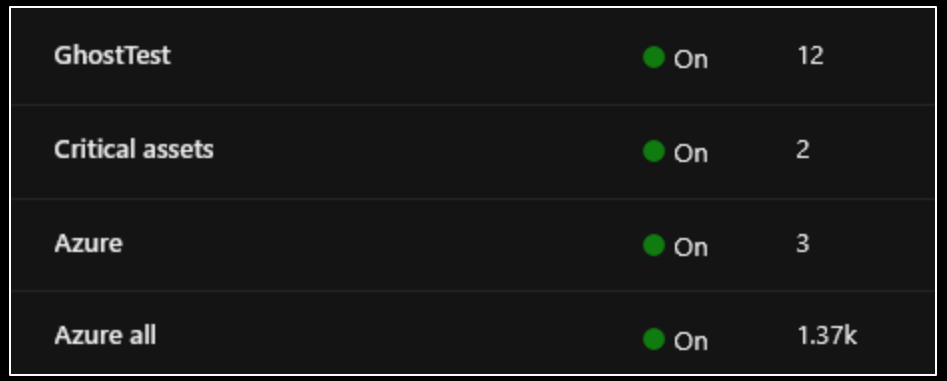


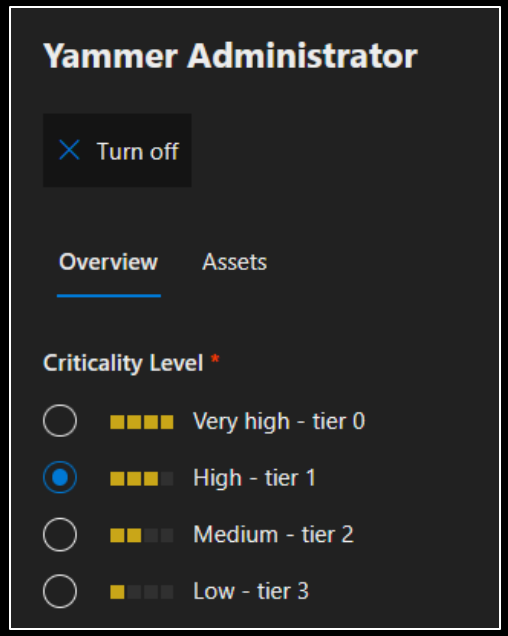


Mapping and identifying critical assets

Define critical assets, identities and resources to look after.

You could add everything in there – but focus first on the actual critical assets such as the leadership team, high-value services and resources.





Defender External Attack Surface Management
(Defenderin ulkoinen hyökkäyspintojen hallinta) 🤦

Scan, monitor and detect externally exposed assets

Seeds can be domain names, IP address ranges, email addresses and other indicators.

Integrates with MSEM and Security Copilot.

Seeds

Type	Seed name
Domain	jussiroine.com
Contact	jussi.roine@northadvisors.com
Domain	northadvisors.com
Domain	roine.org
Domain	notbadsecurity.com
Domain	roine.fi
Contact	jussi@roine.fi
Contact	jussi.roine@notbadsecurity.com
Organization name	Roine
Organization name	North Advisors
Organization name	Not Bad Security



DEMO – MSEM and EASM overview



MSEM and EASM in practice

Onboarding MSEM



Onboard core services:
Defender for Cloud
Defender for Endpoint



Define critical devices
and resources



Define permissions
(Defender XDR RBAC)



Define critical identities



Connect all other services:
EASM, MDI, MDO, etc.



Kick back, relax,
eat a bit of broccoli
and find success.

Licensing

Licenses that allow access to all MSEM experiences:

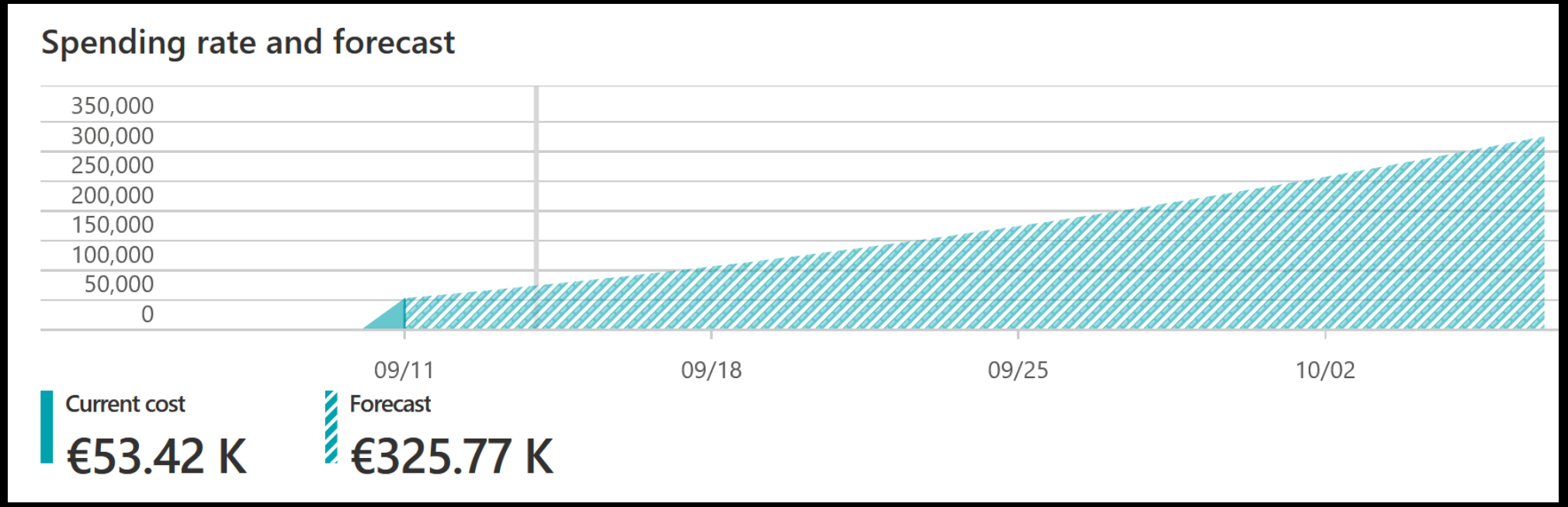
- Microsoft 365 E5/A5
- Microsoft 365 E3 with E5 Security add-on
- Windows 10/11 Enterprise E5/A5
- Office 365 E5/A5
- Microsoft 365 E3 with EM+S E5/A5 add-on

- MDE
- MDI
- MDA
- MDO (Plan 2)
- Microsoft 365 Business Premium
- Defender for Business
- MDC

Pricing for EASM

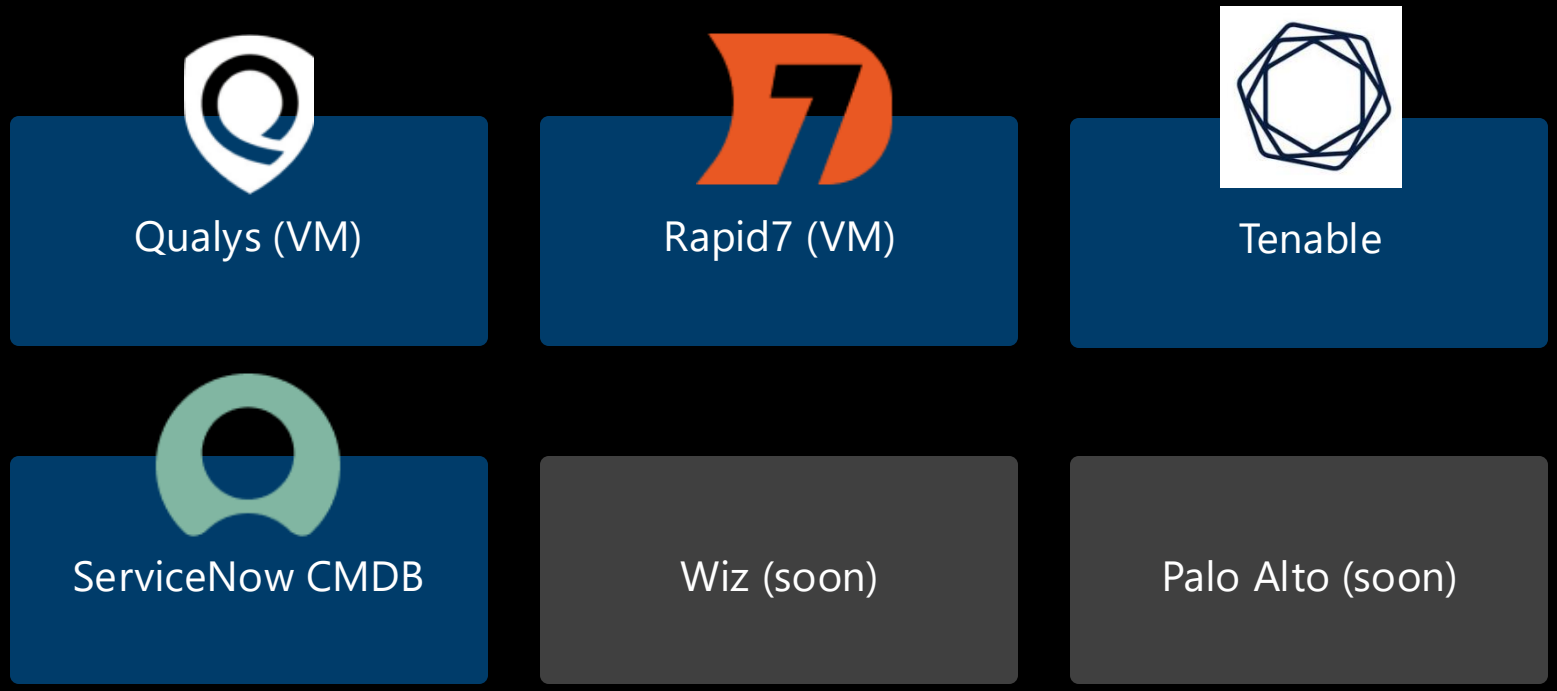
It’s pretty simple, but don’t let this fool you:

0.010 € asset / day



External connectors for MSEM

The following external connectors are available:



Cost? During preview, free. Eventually it will be consumption-based cost for third-party (non-Microsoft) data.

Enterprise Exposure Graph

Advanced Hunting can be utilized for integrations and for proactively finding exposure data.

```
ExposureGraphNodes
| where NodeLabel !in ("iam.user" ,"gcp-user", "user") // Filter out identities
| where EntityIds has_any ("AzureResourceId","AwsResourceName","GcpFullResourceName","CloudResourceNestedObject")
| where isnotnull(NodeProperties.rawData.criticalityLevel) and NodeProperties.rawData.criticalityLevel.criticalityLevel < 4 // Criticality level is "higher" than none
```

ExposureGraphEdges contains relationships between entities and assets.

ExposureGraphNodes contains organizational entities and all their properties.



DEMO – MSEM and EASM in practice

Deployment phases



- Core setup
- Microsoft Sentinel + Defender for Cloud
- Defender EASM
- Defender XDR + MDE
- Entra ID P2/M365 E5 license



- MSEM – Phase 1
- Business Email Compromise
- CIS M365 Foundations Benchmark
- Ransomware Protection
- Attack Paths



- MSEM – Phase 2
- External data connectors
- SaaS Security / Cloud Security
- Enterprise Security Graph
- Automations

Lessons learned




Start planning for business goals
Dial in all data, prepare for future data enrichment
Utilize data and findings everywhere

KIITOS!

Kumppaniarkkitehtiseminaarin esitykset ovat katsottavissa Cloud Championissa

aka.ms/kumppaniarkkitehtiseminaari